

信息安全管理 制度（摘要）

本制度依据 ISO 27001 信息安全管理体系制定，适用于公司全体员工（含外包和实习人员）。全文见公司 Confluence 安全合规空间。

一、信息资产分类

1.1 分类标准

- 公开：对外发布的信息（官网、公告、产品手册等）。无需特殊保护。
- 内部：公司内部流转的信息（项目文档、会议纪要、制度文件等）。泄露可能导致轻微不利影响。
- 机密：部门级敏感信息（财务报表、人事档案、客户合同等）。泄露可能导致重大损失。
- 绝密：公司级战略信息（商业计划、并购方案、核心算法等）。泄露可能导致生存危机。

1.2 存储和传输要求

不同级别信息的存储和传输要求如下：

公开/内部：可使用公司标准设备存储，可通过邮件/IM 内部分享。

机密：必须加密存储（BitLocker 全盘加密），仅限「需要知晓」的人员访问。传输须通过公司批准的加密通道。

绝密：须使用专用加密设备（硬件加密），访问需双人审批+审计日志。原则上禁止网络传输。

二、密码管理

- 密码长度不少于 8 位，须含大写字母、小写字母和数字
- 禁止使用以下弱密码：123456、password、admin、公司名+年份、工号
- 不同系统使用不同密码（禁止一码多用）
- 密码 90 天强制更换，不得与之前 5 次密码重复
- 推荐使用密码管理器（公司提供 1Password Business 授权）
- 发现密码泄露应立即修改并报告信息安全组

三、设备安全

3.1 公司配发设备

- 启用全盘加密（Windows BitLocker / macOS FileVault）
- 安装公司统一的防病毒软件（CrowdStrike Falcon），不得卸载或禁用
- 开启屏幕保护程序，设置 5 分钟无操作自动锁定
- 系统补丁由 IT 统一推送，员工需在收到通知后 48 小时内完成更新
- 离职或换岗时必须交还设备，IT 将执行安全擦除

3.2 移动设备管理（MDM）

- 接入公司邮件/IM 的移动设备须注册 Intune MDM
- 设备须设置至少 6 位数字密码或生物识别锁
- 丢失或被盗应立即远程擦除公司数据（通过 Intune 自助或联系 IT）

四、网络安全

- 办公网络仅限公司设备接入。个人设备使用 Guest-WiFi（仅外网，无内网权限）

- 远程办公必须通过公司 VPN 接入内网（禁止端口映射等绕过方式）
- 禁止在公共场所（咖啡厅、机场等）通过不加密 WiFi 处理机密级及以上信息
- 禁止私自搭建内网服务（如自建 WiFi 热点、代理服务器等）

五、数据保护

5.1 数据备份

- 重要工作文件必须同步至 OneDrive for Business（已自动配置）
- 代码须提交至公司 GitLab，禁止仅保存在本地
- 数据库备份由 IT 统一管理，每日自动备份保留 30 天

5.2 数据销毁

- 纸质机密文件须使用碎纸机销毁（交叉切割型）
- 电子存储介质（硬盘、U 盘）报废前须使用 DoD 5220.22-M 标准擦除或物理销毁
- 离职员工的邮箱和 OneDrive 数据保留 30 天后自动清除

六、安全事件响应

发现以下情况应立即报告信息安全组（分机 1111，邮箱 security@company.com）：

- 电脑中病毒/勒索软件
- 收到可疑的钓鱼邮件并已点击链接/下载附件
- 发现非授权人员在公司区域活动
- 设备或存储介质丢失/被盗
- 发现系统漏洞或数据泄露

安全事件响应流程：

1. 立即断网（拔网线/关 WiFi）
2. 报告信息安全组，保留现场
3. 信息安全组启动应急响应（2 小时内给出初步评估）
4. 重大事件 24 小时内上报管理层

文档版本：v3.1 | 最后更新：2026-05-20 | 维护部门：信息安全组